

API Security Risk Analysis Report

By: Praveena Nagaraju
Date: February 19, 2026

Table of Contents

API Tested.....	1
Identified Risks	1
Business Impact	2
Recommendations.....	5

API Tested

- **Target:** Public demo API (e.g., Swagger Petstore API)
- **Scope:** Read-only inspection of endpoints, headers, authentication, and response behavior.
- **Methodology:** Documentation review, safe GET requests, and response analysis.

Identified Risks

Risk Category	Description	Severity	Business Impact	Remediation
Authentication Gaps	Some endpoints allow unauthenticated access to sensitive operations (e.g., viewing user or order data).	High	Attackers can bypass login and directly query sensitive data.	Enforce authentication on all endpoints; use OAuth2 or JWT-based access tokens.
Excessive Data Exposure	API responses return full objects with unnecessary fields (e.g., internal IDs, metadata).	Medium	Increases risk of data leakage and reconnaissance for attackers.	Implement response filtering; return only required fields.
Rate Limiting Absent	No throttling or quota	High	Attackers can overload	Apply rate limiting (e.g.,

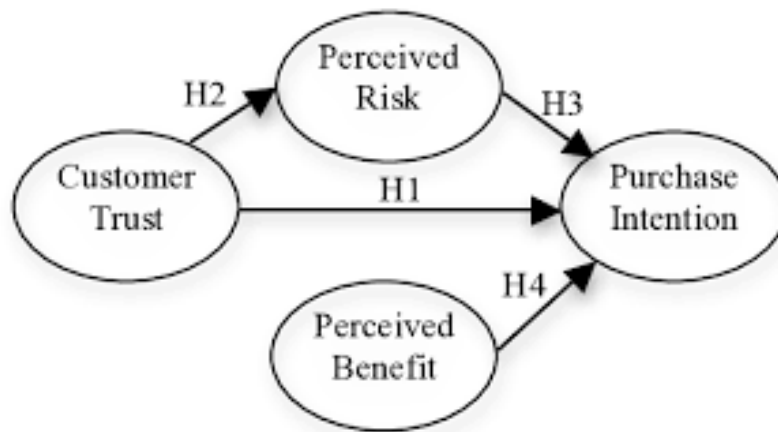
	enforcement observed.		systems with automated requests (DoS or brute force).	API Gateway, WAF rules).
Error Handling Weakness	Error messages reveal stack traces or internal logic.	Medium	Provides attackers with insights into backend structure.	Replace verbose errors with generic messages; log details internally.
Lack of Encryption Enforcement	API accessible over plain HTTP in addition to HTTPS.	High	Exposes sensitive data to interception (MITM attacks).	Force HTTPS; redirect HTTP requests to secure endpoints.
CORS Misconfiguration	Wide-open CORS policy (Access-Control-Allow-Origin: *).	Medium	Allows malicious websites to interact with API directly.	Restrict CORS to trusted domains.
Inconsistent Input Validation	Some endpoints accept arbitrary strings without validation.	Medium	Risk of injection attacks or malformed data storage.	Apply strict schema validation (JSON schema, parameter sanitization).

Business Impact

- **Customer Trust Risk:** If attackers' access or leak sensitive data, customers lose confidence in the platform.
 - **Data Breaches**
Exposure of personal or financial data (credit card info, health records, login credentials) undermines confidence in a company's ability to protect customers.
 - **Identity Theft & Fraud**
When stolen data is misused, customers feel vulnerable and may avoid digital platforms altogether.
 - **Reputation Damage**
Even a single incident can tarnish a brand's image, leading to customer churn and reduced loyalty.

- **Transparency Failures**

Companies that delay disclosure or fail to communicate clearly after an incident lose credibility.



- **Compliance Risk:** Unsecured APIs may violate GDPR, HIPAA, or PCI-DSS requirements.

Key Elements of Compliance Risk

- **Legal Obligations**

Companies must adhere to laws like GDPR (EU), HIPAA (US healthcare), or India's DPDP Act. Non-compliance can lead to lawsuits and penalties.

- **Regulatory Standards**

Frameworks such as ISO 27001, NIST, and PCI DSS require organizations to implement specific controls. Failure exposes them to both cyber threats and regulatory action.

- **Governance Weaknesses**

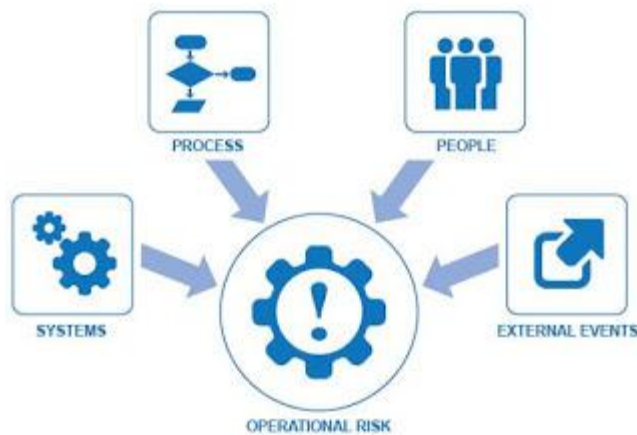
Poor oversight or corruption can undermine compliance, making organizations more vulnerable to cybercrime and enforcement failures.



- **Operational Risk:** Lack of rate limiting can lead to downtime, affecting revenue and SLAs.

Key Sources of Operational Risk in Cybersecurity

- **System Failures**
Outages caused by malware, ransomware, or denial-of-service attacks disrupt business operations.
- **Human Error**
Employees clicking phishing links or misconfiguring systems can open the door to attackers.
- **Process Weaknesses**
Lack of proper incident response or weak access controls increases vulnerability.
- **Third-Party Dependencies**
Vendors and supply chains may introduce risks if their systems are compromised.
- **External Events**
Geopolitical tensions, fraud, and financial crime amplify cyber-related operational risks.



- **Reputation Risk:** Public breaches damage brand reputation and investor confidence.

Drivers of Reputation Risk

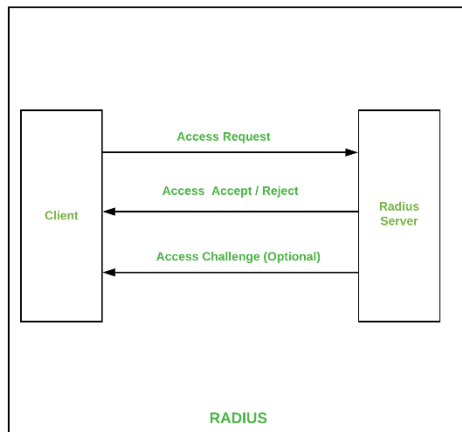
- **Data Breaches:** Exposure of sensitive customer or partner data creates public distrust.
- **Poor Incident Response:** Delayed or opaque communication worsens perception.
- **Media Coverage & Social Amplification:** Negative stories spread quickly, magnifying damage.
- **Stakeholder Expectations:** Customers, regulators, and investors expect strong cybersecurity practices.

Recommendations

- **Authentication & Authorization:** Require strong token-based authentication for all endpoints.

Why They Matter

- “Authentication without authorization” → Anyone verified could access everything (dangerous).
- “Authorization without authentication” → System wouldn’t know who is requesting access.
- Together, they form the foundation of secure access control in modern cybersecurity.



- **Data Minimization:** Return only necessary fields in API responses.

Benefits

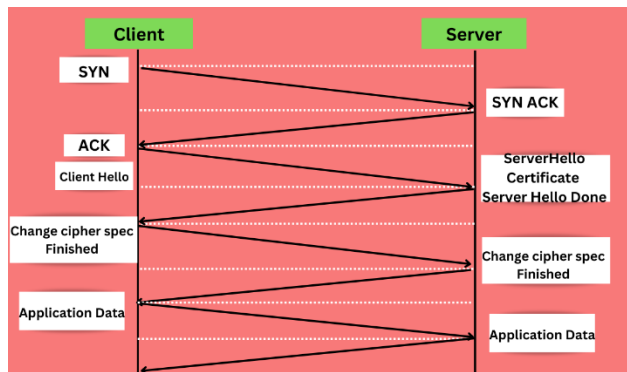
- **Reduced Attack Surface:** Less data means fewer opportunities for attackers to exploit.
- **Lower Compliance Risk:** Aligns with privacy regulations like GDPR and CCPA.
- **Cost Efficiency:** Minimizes storage and management overhead.
- **Improved Trust:** Customers feel safer when organizations don't hoard unnecessary personal data.

Implementation Strategies

- **Data Audits:** Regularly review what data is collected and why.
- **Anonymization & Pseudonymization:** Strip identifiers where possible.
- **Retention Policies:** Automate deletion after a set period.
- **Access Controls:** Enforce least privilege principles.
- **Encryption:** Protect sensitive data that must be stored.

Risks of Ignoring Data Minimization

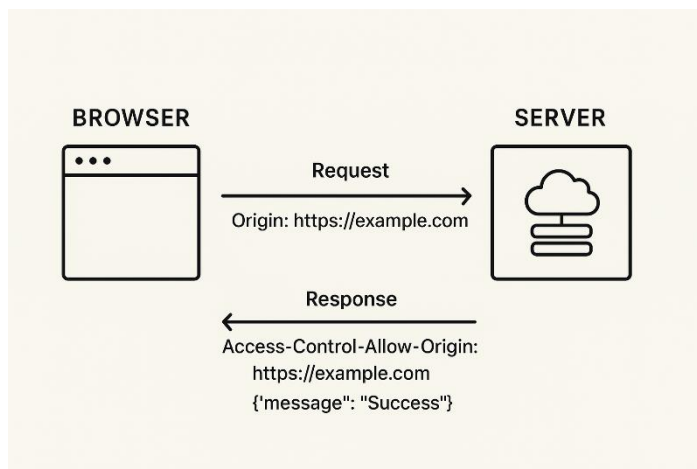
- **Insider Threats:** Employees may misuse excess data.
 - **Data Breaches:** Larger datasets attract attackers.
 - **Regulatory Penalties:** Non-compliance with privacy laws can lead to fines.
 - **Reputation Damage:** Customers lose trust when organizations over-collect or mishandle data.
- **Rate Limiting & Monitoring:** Implement quotas, throttling, and anomaly detection.
 - **Secure Error Handling:** Show generic error messages; log details internally.
 - **Transport Security:** Enforce HTTPS with TLS 1.2+; disable insecure protocols.



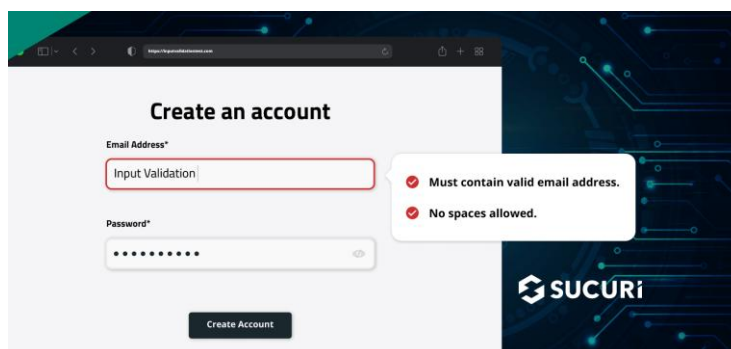
- **CORS Hardening:** Restrict origins to trusted domains.

Key Risks of Weak CORS

- **Overly permissive origins:** Allowing or multiple domains without restriction.
- **Exposed credentials:** Misuse of can leak session tokens.
- **Improper preflight handling:** Weak validation of requests can bypass restrictions.
- **Privilege escalation:** Attackers can impersonate users or access protected APIs.



- **Input Validation:** Use strict schemas and sanitize all inputs.



- **Regular Security Audits:** Schedule penetration testing and automated scans.